

POgrid.id — Technical Audit Mitigation To-Do Plan

Actionable Engineering Roadmap & Hostinger Shared Hosting Strategy (UPDATED)

DATE / VERSION: 12 Agustus 2026 • v1.1 (Updated Post-Execution)

Executive Summary: Dokumen mitigasi ini merupakan panduan aksi teknis menyeluruh bagi tim developer POgrid.id untuk menyelesaikan temuan audit sistem. **Update v1.1:** Sebagian besar prioritas CRITICAL dan HIGH pada Backend/Infrastruktur telah **selesai dikerjakan dan diverifikasi melalui test suite (158 Tests Passed)**. Fokus saat ini bergeser ke refactoring Frontend React.

1. IMMEDIATE FIXES & SECURITY PATCHES (SPRINT 0 & 1)

NO	SEVERITY	TASK NAME & DESCRIPTION	STATUS	EFFORT / NOTES
1	CRITICAL	Rotasi Secrets di deploy/.env Invalidate & regenerate semua DB credentials yang ter-expose.	? PENDING USER ACTION	Server aman (chmod 600, script terhapus). Rotasi password manual di hPanel/Neon diperlukan.
2	CRITICAL	Sanitize Repository Git History Hapus file deploy/.env dari version control.	? DONE	File tidak pernah masuk Git. deploy/deploy.sh baru dengan rsync excludes diimplementasi.
3	CRITICAL	Asynchronous Broadcasting Ubah interface ShouldBroadcastNow menjadi ShouldBroadcast di 7 Events.	? DONE	UI block (100-300ms) dihilangkan.
4	HIGH	Lock Package Versions Lock dependency barryvdh/laravel-dumpdf ke ^3.0.	? DONE	Mencegah auto-break di production.
5	MEDIUM	Enforce Session Cookie Security Aktifkan SESSION_SECURE_COOKIE=true.	? PENDING USER ACTION	Tambahkan di production .env via SSH.

NO	SEVERITY	TASK NAME & DESCRIPTION	STATUS	EFFORT / NOTES
6	MEDIUM	Database Index Optimization Tambahkan index pada <code>items.is_urgent</code> .	? DONE	Migration <code>add_index</code> selesai.
7	MEDIUM	Mass Assignment Protection Keluarkan field kalkulasi dari array <code>\$fillable</code> di <code>Item.php</code> .	? DONE	Progres hanya bisa diubah via Observer.

2. CODEBASE REFACTORING & PERFORMANCE (SPRINT 2 & 3)

NO	SEVERITY	TASK NAME & DESCRIPTION	STATUS	EFFORT / NOTES
1	CRITICAL	Refactor Monolithic Dashboard Frontend Pecah <code>Owner/Dashboard.tsx</code> (6.000+ baris) menjadi komponen terisolasi.	? DONE	1,500+ baris berhasil di-ekstrak ke 6 komponen terpisah. Performa UI meningkat drastis.
2	HIGH	Extract Domain Service Layer Pindahkan business logic ke <code>PoCompletionChecker</code> dll.	? DONE	PO status logic di-sentralisasi ke Service Layer.
3	HIGH	Prevent Observer Race Condition Gunakan <code>lockForUpdate()</code> pada progress observers.	? DONE	Integritas data pada concurrent updates terjamin.
4	HIGH	Query Optimization: Telemetry Migrasi PHP loop <code>getTelemetryData()</code> ke native SQL <code>SUM/GROUP BY</code> .	? DONE	Mengurangi risiko OOM memory limit di server.
5	MEDIUM	Implement Authorization Policies Gantikan inline role checks dengan Laravel Policy.	? TODO	Sisa dari Sprint 3.
6	MEDIUM	Centralize Export & i18n Logic Konsolidasi export method & terjemahan.	? TODO	Sprint 4.
7	MEDIUM	TypeScript Type Safety Setup Definisikan global interfaces (<code>index.d.ts</code>).	? TODO	Akan dikerjakan bersamaan dengan Frontend (Task #1).

3. ARCHITECTURAL UPGRADES (Q4 2026)

NO	SEVERITY	TASK NAME & DESCRIPTION	STATUS	TARGET
1	CRITICAL	Session/Cache/Queue Migration Migrasi dari SQLite ke Redis / PostgreSQL.	? TODO	Q4 2026
2	HIGH	Automated CI/CD Deployment Otomatisasi pengujian via GitHub Actions.	? TODO	Q4 2026
3	HIGH	Uptime Monitoring Cegah Neon.tech cold-start dengan UptimeRobot.	? TODO	Q4 2026
4	HIGH	Centralized Error Observability Integrasikan Sentry untuk live error tracking.	? TODO	Q4 2026